

Cybersecurity

Introduction to Incident Response

Lesson 21.1



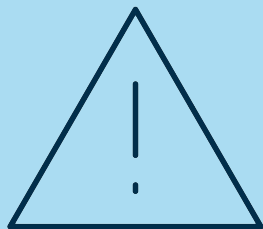
Learning Objectives

By the end of today's lesson, you will be able to:

- 1 Identify the types of incidents typically escalated to incident response managers.
- 2 List who makes up a Security Incident Response Team (SIRT) and their roles.
- 3 Identify how an incident response plan can guide the SIRT when an incident occurs.
- 4 Use the malware testing tool ANY.RUN to dynamically analyze ransomware.



Welcome



Introduction to **Incident Response**

This week, we will learn
about **DFIR**, which stands
for Digital Forensics and
Incident Response.



Incident Response and Digital Forensics Module



Intro to Incident Response

We have covered various threats that can negatively affect a company, including:

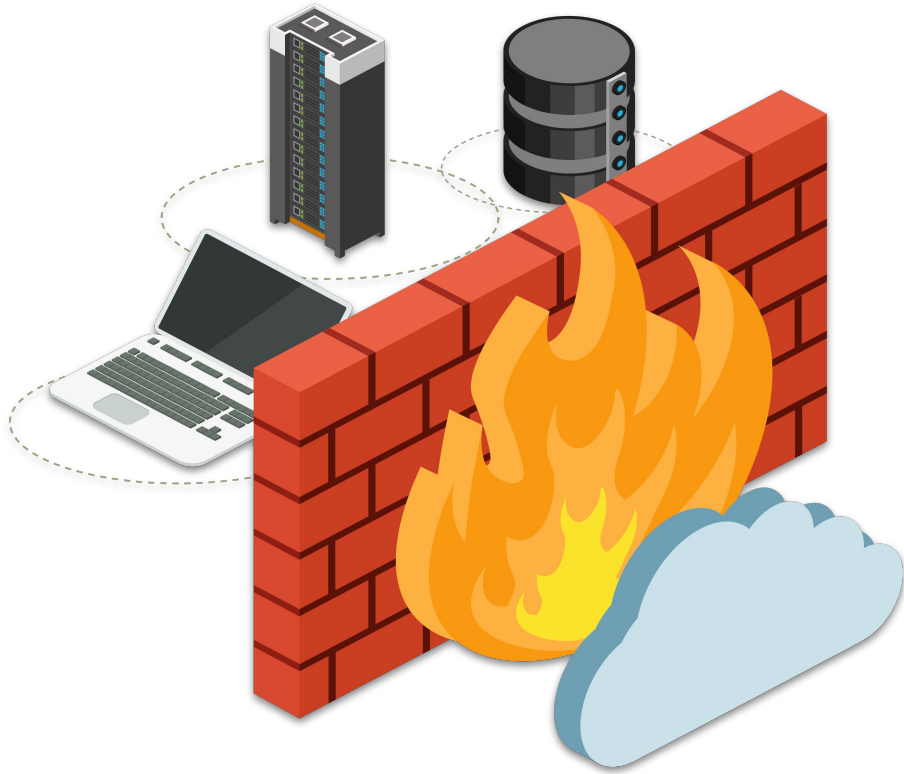
- Malware
- DDoS attacks
- Botnet attacks
- Phishing
- Data breaches

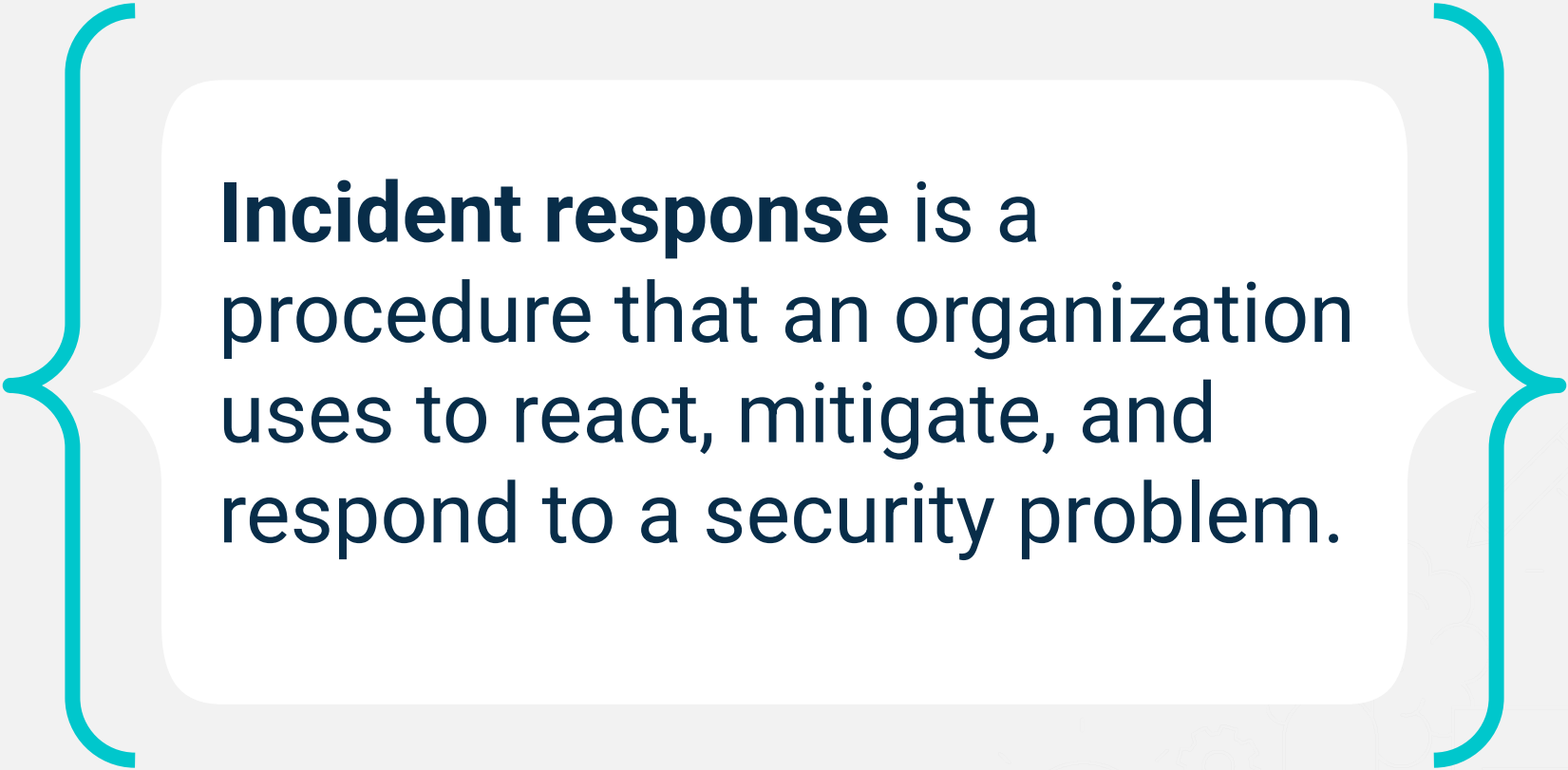


Intro to Incident Response

Companies put in place security systems to prevent these incidents, such as:

- System firewalls
- Intrusion Prevention Systems (IPS)
- Network security firewalls
- Application security



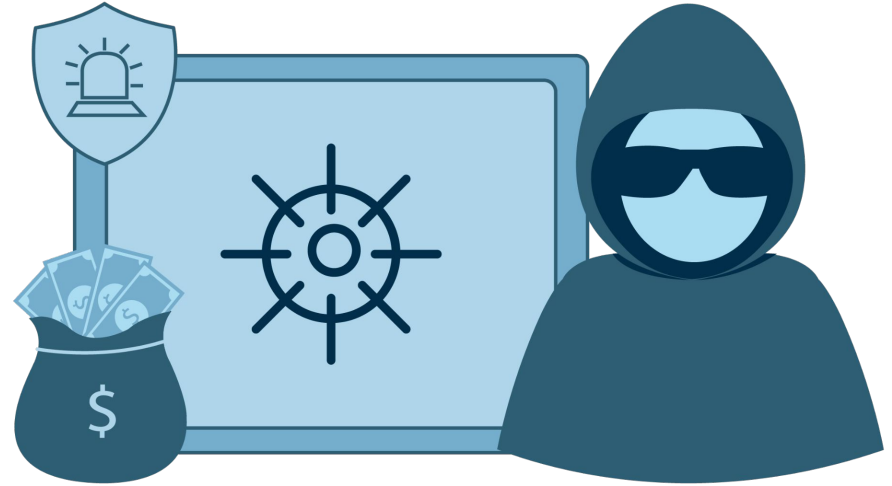


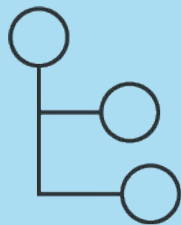
Incident response is a procedure that an organization uses to react, mitigate, and respond to a security problem.

Intro to Incident Response

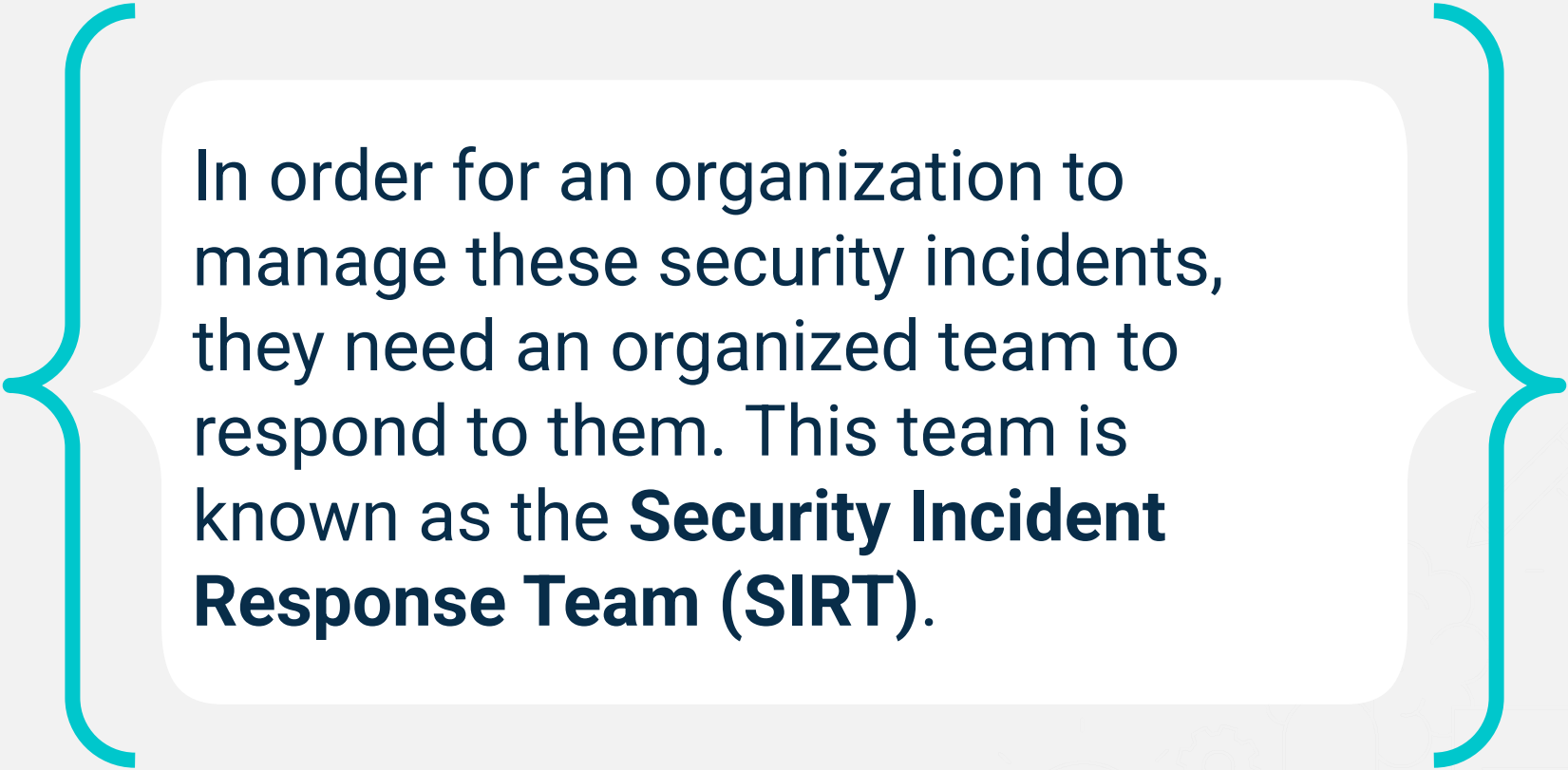
If we think of a company as a bank, its security systems are similar to the bank's alarm and security guards.

We can consider the threats to be bank robbers, and the **incident response** to be like the police responding after the bank alarm went off and the robbers broke in.





SIRT Structure



In order for an organization to manage these security incidents, they need an organized team to respond to them. This team is known as the **Security Incident Response Team (SIRT)**.



SIRT Structure

Most SIRTs are typically made up of the following roles:



- Security operations staff
- Incident responders and incident response managers
- Aligned staff:
 - Legal
 - Compliance
 - Communications, PR
 - Engineers



First responders to handle security issues work out of a **security operations center**, or a **SOC**.



Security Operations Center (SOC)

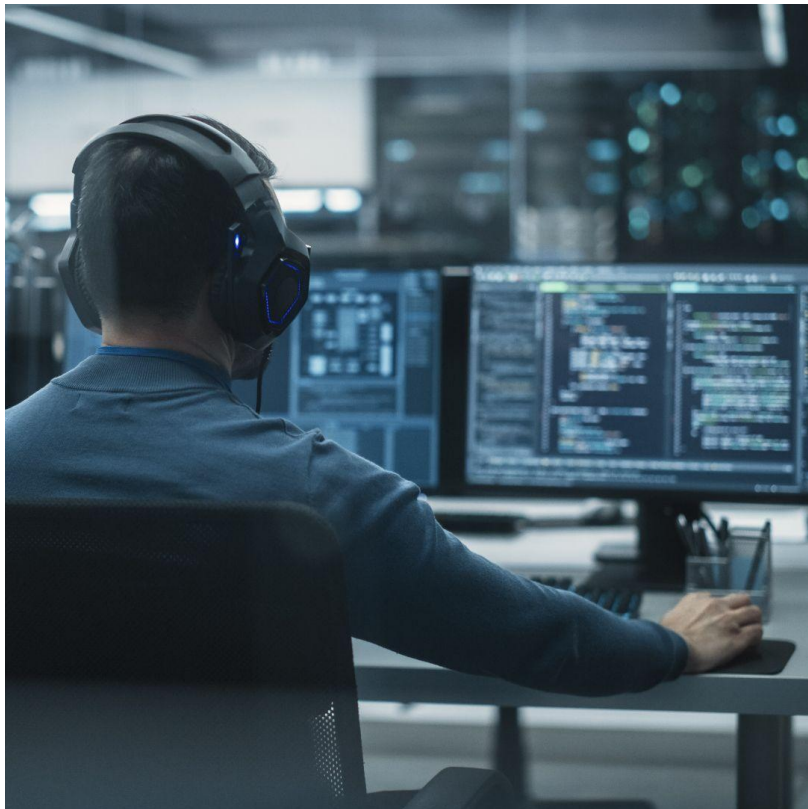
Within a SOC are SOC analysts who are often organized in three tiers:





SOC Staff

Tier 1



Junior analysts are the first responders and first line of defense.

- Often in charge of monitoring alerts and verifying that they are not false positives.
- Follow pre-planned procedures, perform an initial investigation, solve simple incidents, and escalate as needed.
- Entry-level role and starting point for most students who choose this career path.

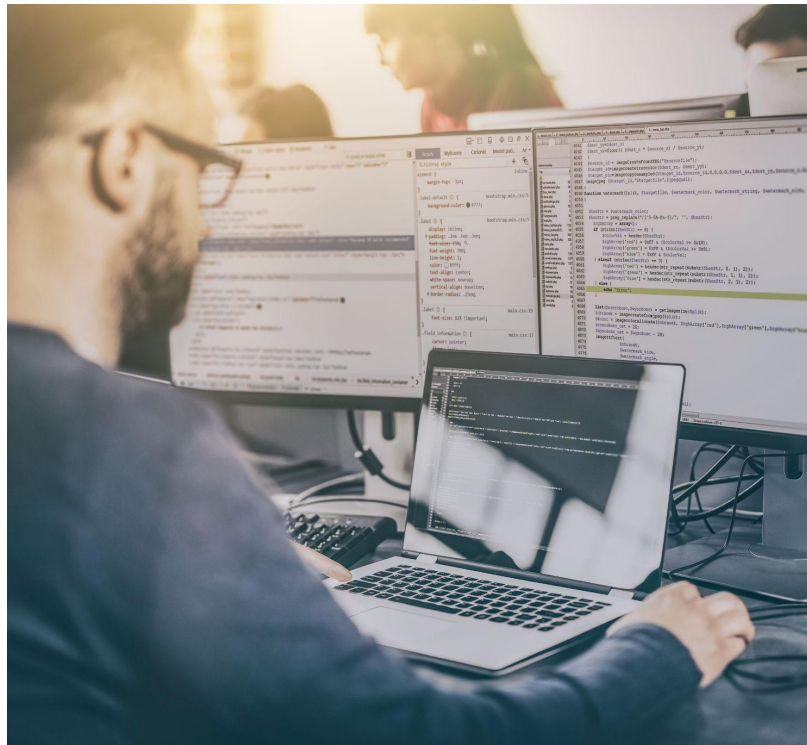


SOC Staff

Tier 2

Tier 2 is the first escalation point for Tier 1 analysts:

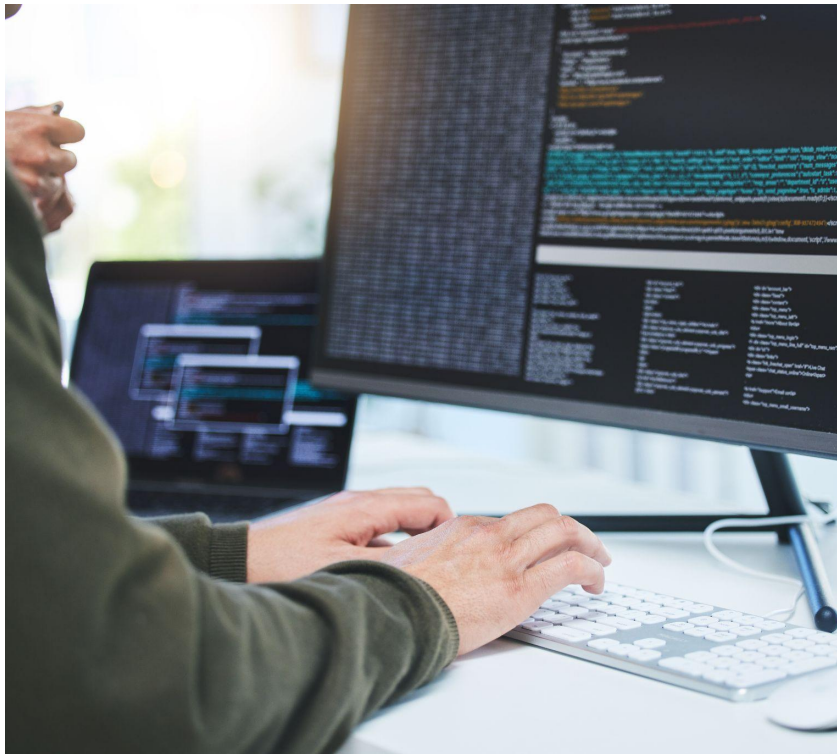
- Help get past any blockers that the Tier 1 analyst may have.
- Can perform the duties of Tier 1 as needed, but can also divert from written procedures.
- Also support Tier 3 as needed, and create documentation and procedures for Tier 1 and monitor Tier 1's performance.





SOC Staff

Tier 3



Tier 3 is the second escalation point for Tier 1 analysts and may serve more of a forensics or deep investigative role:

- Often own the tools used by the incident response team.
- Oversee complex incidents.
- Mentor and monitor the performance of all other tiers.

SOC managers can perform all of the duties of a Tier 3 analyst, but also manage the team and have the HR responsibilities of growing and maintaining the team.



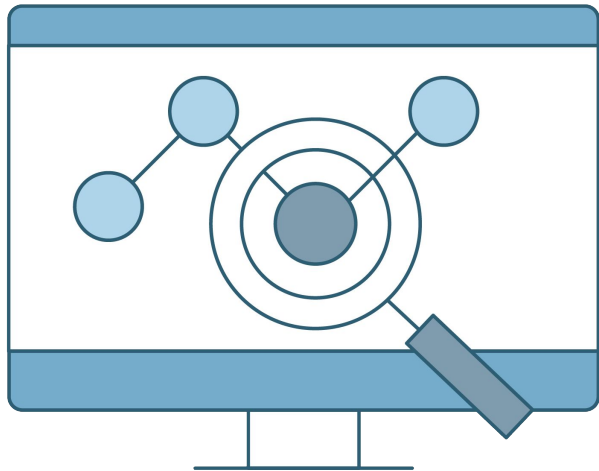


SOC staff responsibilities include determining if a security issue is considered to be a high priority incident that requires an **incident response manager** to intervene.



Security Operations Center (SOC)

Analysts are typically provided with directives as to what type of incident requires escalation.



There will be many times when analysts will encounter unique issues that will require their professional judgement.

Issues that can impact the entire organization technically, financially, or reputationally usually require **escalation**.



A SOC analyst determined that one employee had their account breached, the employee had data of all the organization's customers obtained by the attacker.

Does this situation require escalation?



Activity

Escalation or not

You are a SOC analyst working for a financial services organization.

- There have been multiple security issues at your organization.
- Your task is to review the following issues and determine if these require escalation to the SIRT.

Suggested Time
20 minutes

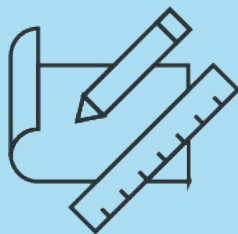


Time's Up!
Let's review



Questions?

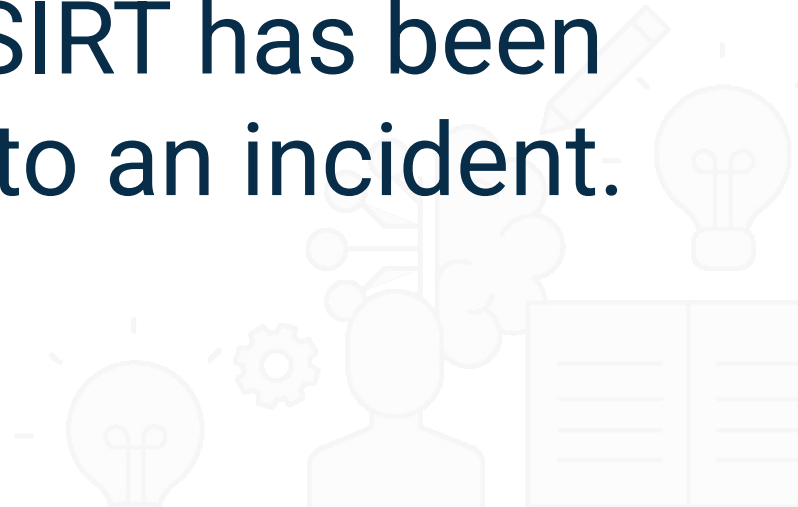




Incident Response Plans



This next section will cover what takes place **after** the SIRT has been assigned to an incident.



Incident Response Plans

Let's cover some important terms used by the SIRT:

Bridge (Bridge Call)	Conference call or communication channel where the SIRT discusses a specific security issue.
Incident Response Plan	Formal high-level document detailing how the organization will respond to incidents.
Response Process	More general document not as formal as an incident response plan.
Response Procedure	Step-by-step workflow for a given part of a response often organized in a flowchart.
Incident Response Playbook	Collection of procedures for a given type of incident.

Incident Response Plans

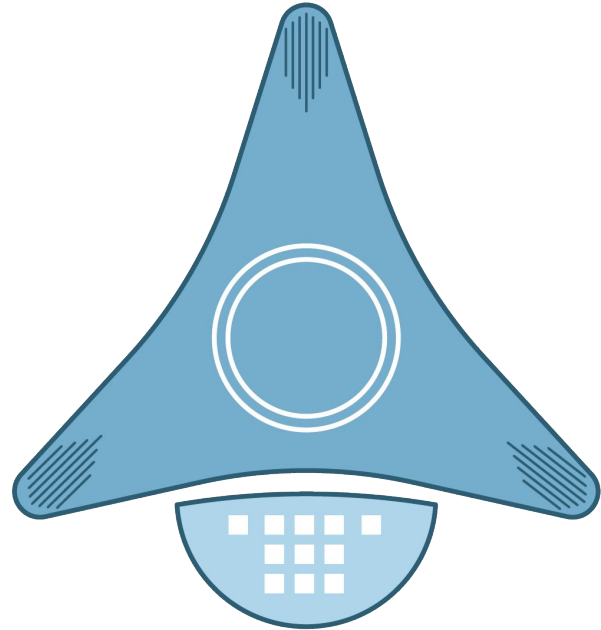
Let's cover some important terms used by the SIRT:

Root Cause Analysis (RCA)	Process or report that determines the root reason why the incident occurred.
Post-Incident Report	Process and document designed to provide an overview of what the analyst found and what they did in response to a particular incident.
Tabletop Exercise	Common exercise where a security team is given an incident scenario and they detail the steps they would take to respond to it.

SIRT First Steps

Now that we know the terms used by the SIRT, let's get into the incident response process.

- A common first step taken by an incident response manager is to open a **bridge**.
- All required teams that understand the issue will be invited.

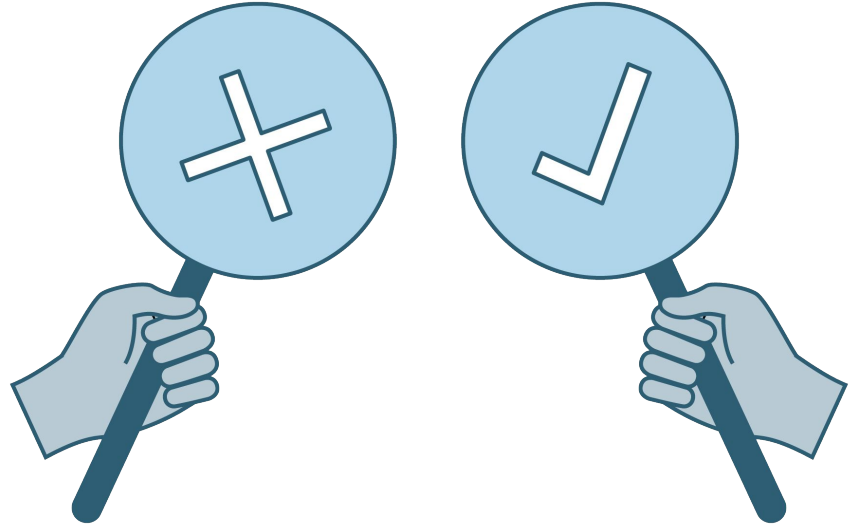


SIRT First Steps

Subject matter expert (SME)

Next, the incident response manager will have a SME explain the issue and its potential impact.

- The SME will determine if the issue could potentially be a **false positive** before escalating further.



An incident response manager may not be an expert on every possible incident. It is very common to call in a **SME** to assist in the response effort.

Simple Incidents

**Phishing attacks
or malware downloads**

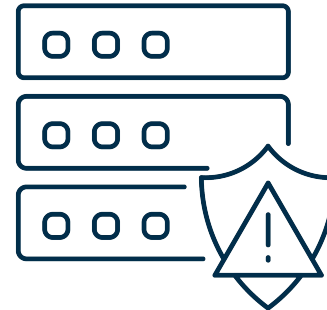
Usually opportunistic attacks that can be solved by junior analysts following specific steps.



Complex Incidents

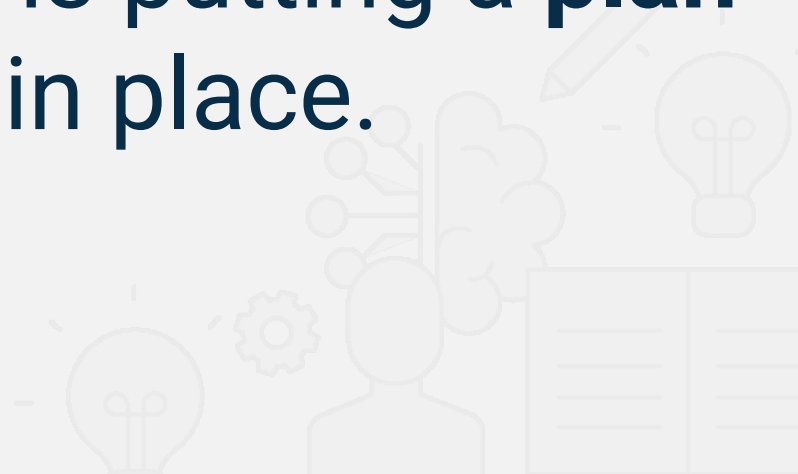
**Attacks that affect multiple
employees and/or servers**

More coordinated attacks that have a higher severity. May involve multiple incident response team members and/or multiple IT teams.





The next step of incident response is putting a **plan of action** in place.





Incident Response Plans

Every company should have a documented plan

An incident response plan should cover:

- When to respond
- What to do and how to do it
- Who is in charge

Organizations should also have different response plans for different incidents, like

- Data breaches
- DDoS attacks
- Application security vulnerabilities





Incident Response Plans

An incident response plan should help cover the process that needs to be followed and answer these common questions:



- Do you immediately take systems offline and just send a notification?
- Who makes the decision to shut down systems?
- Do you need management approval to shut down systems?
- Who needs to be notified?
- Will this affect company revenue or customer experience?
- At what point do you involve the PR department?
- At what point do you involve the legal team?
- Who communicates the issue to the executive team?



Activity

Interpreting incident response plans

In this activity, you will compare and contrast several incident response plans from different companies.

- This activity is meant to provide an overview of real-world incident response plans from companies in different sectors and industries.
- Try not to get overwhelmed by the volume of these documents. Focus your attention on each document's table of contents and one section of your choosing to compare across the documents.

Suggested Time
40 minutes



Time's Up!
Let's review

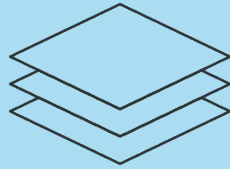


Questions?





Break
15 mins



Developing an Incident Response Plan



If you had to write an incident response plan for your company, it would be useful if there were some kind of **standard framework** that your organization could follow.

Developing an Incident Response Plan

The National Institute of Standards and Technology (NIST) sets **the** industry standard for incident response plans.

It offers a detailed plan and process descriptions for everything involved in an incident.

Companies can also use the NIST standard as a framework for building out their own plans.

An incident response plan must be **continually** executed, assessed, and updated to keep up with current threats.

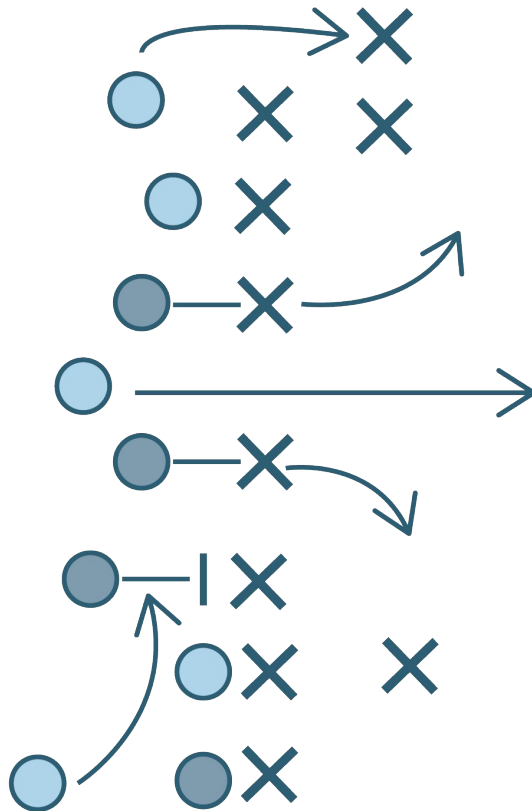


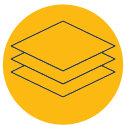
Incident Response Playbook

An incident response playbook lists the steps that need to be taken to respond to security incidents.

It can be split into various procedures. The common phases of an incident response playbook include:

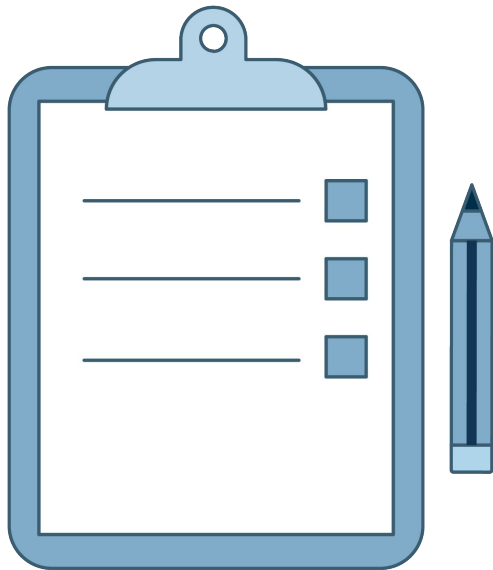
1. Prepare
2. Detect and analyze
3. Contain, eradicate, and recover
4. Post incident





Incident Response Playbook

Phase 1: Prepare



Identify key contacts and steps taken **before** any analysis takes place. The **prepare phase** often includes determining and documenting the following:

- Systems, network diagrams, and baselines
- Clean OS and application images available
- How to handle hardware and software
- Who is going to monitor and who is going to respond
- Key stakeholders and their contact info



Incident Response Playbook

Phase 2: Detect and analyze



Validate, identify, and prioritize the issue.
The **detect and analyze phase** often includes determining and completing the following:

- System logs and IDS/IPS system alerts
- Anti-virus software alerts
- Host-based monitor detecting configuration change
- Network traffic anomalies
- Characteristics and indicators of a threat
- Business impact
- Incident priority



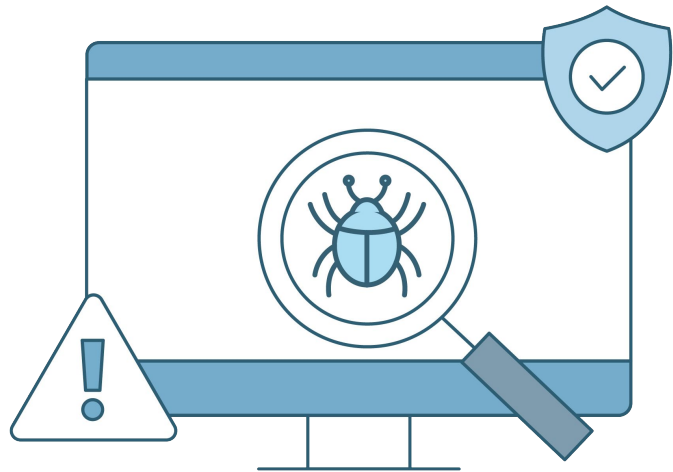
Incident Response Playbook

Phase 3: Contain, eradicate, and recover

Prevent the issue from worsening by removing and stopping it while recovering all business capabilities.

The **contain, eradicate, and recover phase** includes:

- System isolation
- Disabling breached user accounts
- Replacing compromised files
- Determining affected systems
- Identifying attack tools, methods, and vectors
- Communicating needed actions with teams
- Verifying incident has been removed with updated monitoring
- Recovering affected systems or restoring from backup
- Determining steps that should be taken on affected servers or systems
- Erasing systems, firewall updates, patches etc.





Incident Response Playbook

Phase 4: Post incident

Understand the specifics of what caused the issue, and how to improve on future responses and mitigate future issues. The **post incident phase** includes:

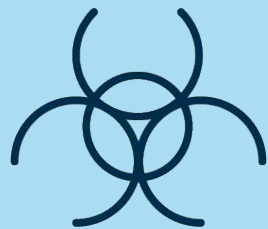
- Learning and improving
- Holding post-incident meeting
- Reviewing detailed timestamp of events
- Re-evaluating incident response plan
- Updating system alerts to ensure better accuracy
- Reviewing changes applied
- Updating response workflow
- Documenting and reporting





Questions?





Responding to a Malware Incident With **ANY.RUN**



Responding to a Malware Incident

Many organizations are concerned with malware infections

If a hospital were infected by **ransomware**, it may be unable to access medical data, which could affect the health of its patients.

Organizations are often challenged with how to respond to incidents when malware has potentially infected their network. Common questions they should ask include:

- How and when was the user or machine infected?
- Were any other users or machines infected?
- What was the impact of the malware?



Responding to a Malware Incident

Running live malware is inherently dangerous, so analysts need to use special environments.

Static Malware Analysis Tools

Analysis of raw source code.

Look for things like IP addresses (reveal C2 servers), ports, processes

Dynamic Malware Analysis Tools

Analysis of what the malware does when it runs.

Look for things like Wireshark captures to identify "phoning home" (communication with C2 servers), suspicious changes to the file system or registry, etc.



In this lesson, we will learn how to use the dynamic malware analysis tool **ANY.RUN**.



Responding to a Malware Incident with ANY.RUN

ANY.RUN is a web-based dynamic malware analysis tool.

It can provide:

- An interactive sandbox where a security engineer can view how the malware responds to different scenarios.
- Insights into how the organization may or may not be impacted.
- Network details showing how the malware communicates by identifying IP addresses and suspicious domains.



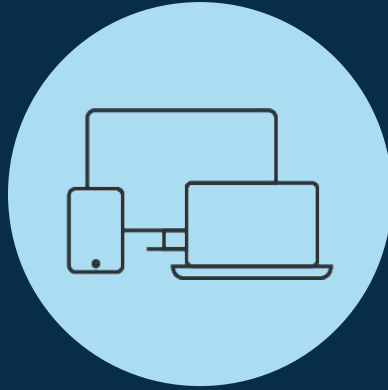


Demonstration Scenario



We will use the ANY.RUN tool to analyze the Adylkuzz malware.

- Adylkuzz is a cryptocurrency mining malware that hides in the background and uses a computer's resources to mine the digital currency Monero.



Instructor Demonstration

ANY.RUN



Activity

Analyzing ransomware with ANY.RUN

In today's final activity, you will play the role of an incident responder tasked with analyzing malware that has infected a user's computer at your organization.

- You are tasked with safely analyzing the malware and completing a report about the impact of the incident to your organization.

Suggested Time
30 minutes



Time's Up!
Let's review



Questions?





Next Class

Introduction to digital forensics



Thank You